



Forget Me



Bối cảnh (Context)

Mạng xã hội ConnectUS nhận được phản nản rằng tính năng quên mật khẩu của họ quá rườm rà. Lắng nghe người dùng, đội Dev đã tung ra tính năng lấy lại mật khẩu nhanh bằng cách gửi một đường link kèm token đến email của người dùng.

Tuy nhiên, để "tiện lợi" cho việc debug trong quá trình phát triển, đội Dev có vẻ đã tùy biến một chút trong cơ chế tạo mã khôi phục hoặc cách gửi email, khiến hacker có thể cướp quyền truy cập của bất kỳ ai.



Mục tiêu (Objective)

- **Nhiệm vụ:** Bạn cần thực hiện việc đổi mật khẩu của tài khoản Admin mà không cần truy cập vào hòm thư email của Admin.
- **Vấn đề / Lỗ hổng:** Tính năng quên mật khẩu dính lỗi **Broken Authentication** hoặc **Host Header Injection / Parameter Pollution**. Có thể hệ thống cho phép chèn thêm tham số email phụ vào request, gửi token tới mail kẻ tấn công, hoặc mã OTP sinh ra quá ngắn và dễ đoán (Bruteforce).
- **Flag:** Đăng nhập thành công vào tài khoản Admin sau khi đã đổi mật khẩu.



Gợi ý (Hints)

- Khi yêu cầu gửi link khôi phục mật khẩu, hãy chặn request bằng Burp Suite.
- Thử gửi 2 tham số email cùng lúc (`email=admin@site.com&email=hacker@site.com`), hoặc thay đổi `Host` header xem link reset có đổi domain sang máy chủ của bạn không.
- Mã token reset có tuân theo một quy luật thời gian nào không?